

Bezpečnostná politika — VšetohEvidencia

Hlásenie zraniteľností

Ak objavíte bezpečnostnú zraniteľnosť, kontaktujte administrátora aplikácie priamo a nie cez verejný issue tracker. Uveďte podrobný popis, kroky na reprodukciu a závažnosť nálezu.

Bezpečnostný audit (2026-05-06)

Aplikácia prešla hĺbkovým auditom podľa štandardov OWASP Top 10. Nižšie je zdokumentovaný stav po aplikovaní opráv.

Opravené zraniteľnosti

KRITICKÁ — Backdoor v autentifikácii (A07)

Súbor: `src/lib/auth.ts`

Podmienka `credentials.password === "test"` umožňovala prihlásiť sa s heslom `test` pre ľubovoľný účet. Odstránená. Autentifikácia teraz prebieha výlučne cez `bcrypt.compare()`.

Zároveň pridaný session timeout: JWT tokeny expirujú po 8 hodinách nečinnosti.

KRITICKÁ — Chýbajúce HTTP bezpečnostné hlavičky (A05)

Súbor: `next.config.ts`

Aplikácia nevracala žiadne ochranné HTTP hlavičky. Pridané pre všetky odpovede:

Hlavička	Hodnota	Účel
<code>Content-Security-Policy</code>	<code>default-src 'self'; frame-ancestors 'self'; ...</code>	Zabraňuje XSS a clickjackingu
<code>X-Frame-Options</code>	<code>SAMEORIGIN</code>	Ochrana pred clickjackingom
<code>X-Content-Type-Options</code>	<code>nosniff</code>	Zabraňuje MIME type sniffingu
<code>Referrer-Policy</code>	<code>strict-origin-when-cross-origin</code>	Obmedzuje únik URL v Referer
<code>Permissions-Policy</code>	<code>camera=(), microphone=(), geolocation=()</code>	Zakazuje prístup k senzitívnym API

VYSOKÁ — Slabá politika hesiel + chýbajúca autorizácia roly (A07 / A01)

Súbor: `src/app/dashboard/users/actions.ts`

- Minimum zvýšené zo 6 na **10 znakov**; heslo musí obsahovať aspoň jedno veľké písmeno, jedno malé písmeno a jednu číslicu.
- Funkcie `createUser`, `updateUser` a `setUserRoomAccess` nekontrolovali rolu volajúceho — opravené na povinnú rolu `SPRAVCA_KARIET`.

VYSOKÁ — Path traversal pri sťahovaní súborov (A01)

Súbory: `src/app/api/dokumenty/file/[filename]/route.ts`,
`src/app/api/travel/file/[filename]/route.ts`

Pôvodná kontrola `filename.includes("..")` bola nedostatočná. Nahradená za `path.resolve()` s explicitným overením, že výsledná cesta zostáva v rámci `uploads/` adresára.

VYSOKÁ — Nebezpečný inline rendering súborov v prehliadači (A03)

Súbory: oba file-serving endpointy

`Content-Disposition: inline` dovoľoval prehliadaču potenciálne spustiť nahraté HTML/JS súbory. Zmenené na `Content-Disposition: attachment`. Pridaný `X-Content-Type-Options: nosniff`.

VYSOKÁ — Chýbajúci whitelist prípon pri nahrávaní (A03)

Súbory: `src/app/api/attachments/route.ts`, `src/app/dashboard/pracovne-cesty/actions.ts`

Nebola kontrola prípony — bolo možné nahrať `.exe`, `.sh` a podobné súbory. Pridaný explicitný whitelist povolených prípon:

```
pdf, doc, docx, xls, xlsx, png, jpg, jpeg, gif, txt, csv
```

STREDNÁ — Information leakage v chybových správach (A09)

Súbor: `src/app/dashboard/assets/actions.ts`

Chybová správa pri duplicitnom výrobnom čísle odhaľovala interné ID záznamu v databáze. Upresnená na všeobecnú správu bez interných detailov.

Implementované bezpečnostné prvky

Autentifikácia a správa relácií

- Heslá hashované algoritmom **bcrypt** s cost faktorom 12
- JWT tokeny expirujú po **8 hodinách**
- NextAuth middleware chráni všetky `/dashboard/*` cesty — neautentifikovaní používatelia sú presmerovaní na `/login`
- Email je normalizovaný na lowercase pred overením (zabraňuje obídeniu cez kapitalizáciu)

Autorizácia

- Každá Server Action overuje rolu volajúceho cez `getSession(authOptions)`
- Dokumenty s dôvernosťou **DOVERNI** majú granulárnu kontrolu prístupu: správca dokumentov, gestor agendy, gestor dokumentu, alebo explicitný prístup
- Sťahovanie súborov pracovných ciest je obmedzené na vlastníka, nadriadeného a správcu PC

Ochrana súborového systému

- Nahrávané súbory dostávajú UUID náhodné meno — pôvodný názov sa nikdy nepoužíva ako cesta
- Whitelist povolených prípon na všetkých upload endpointoch
- Prístup k súborom výlučne cez autorizované API cesty, nie priamo z file systému

Ochrana pred XSS

- Next.js App Router automaticky escapuje všetky JSX výstupy
- V kóde sa nenachádza žiadne použitie `dangerouslySetInnerHTML`, `innerHTML` ani `eval()`
- CSP hlavička obmedzuje zdroje skriptov na `'self'`

Ochrana pred SQL injection

- Všetky databázové operácie prechádzajú cez Prisma ORM s parametrizovanými dotazmi
- V kóde sa nenachádza žiadne použitie `$queryRaw` ani `$executeRaw` s používateľským vstupom

Správa citlivých údajov

- `.env` súbor je v `.gitignore` a nikdy nie je commitnutý
- Premenné prostredia sa načítavajú len na strane servera (nikdy nie v client komponentoch)

Zostávajúce odporúčania

Tieto body neboli implementované a vyžadujú samostatné nasadenie:

Priorita	Odporúčanie
Vysoká	Rate limiting na <code>/api/auth</code> — ochrana pred brute-force útokmi (napr. Upstash Rate Limit)
Vysoká	Zmena predvoleného DB hesla <code>admin123</code> pred produkčným nasadením
Stredná	Audit log — záznam CRUD operácií nad citlivými dátami (kto, čo, kedy)
Stredná	Odstrániť <code>console.log("Heslo: heslo123")</code> zo <code>prisma/seed.ts</code>
Nízka	Dvojfaktorová autentifikácia pre privilegované roly
Nízka	Mechanizmus odvolania JWT tokenov (čierna listina v Redis)